

CVE-2020-17103 / MiniPlasma

Purple Team Threat Intelligence Report

Published: 20 May 2026 | TLP: AMBER

WARNING — AI-ASSISTED REPORT: This report was generated with AI assistance and is provided for informational purposes only. All findings, detection rules, and recommendations must be independently reviewed and validated by a qualified security professional before implementation. Detection queries are templates requiring adaptation to your environment. Verify all details against latest vendor advisories, MSRC, NVD, and CISA guidance.

Vulnerability Metadata	
CVE ID	CVE-2020-17103
Alias	MiniPlasma
Disclosure Date	Original: September 2020 (Forshaw/GPZ) Re-disclosed: 13 May 2026 (Nightmare-Eclipse)
Vulnerability Type	Local Privilege Escalation (LPE) — Race Condition
Affected Component	cldflt.sys — Windows Cloud Filter Driver (HsmOsBlockPlaceholderAccess)
CVSS v3.1 Score	7.8 HIGH (AV:L/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H)
Attack Vector	Local — requires standard user account on target system
Privileges Required	Low (standard user — no admin needed)
User Interaction	None
Exploit Status	Public PoC on GitHub — weaponised, reliable on multi-core systems
Zero-Day	YES — no patch available as of 20 May 2026
Patch Available	No. Next Patch Tuesday: 10 June 2026
Affected Platforms	Windows 11 (all builds), Windows Server 2022, Windows Server 2025
Not Affected	Windows 10, Windows 11 Insider Preview Canary channel
Researcher	Nightmare-Eclipse (GitHub) / Chaotic Eclipse — Exploit Series #6
MITRE ATT&CK	TA0004 Privilege Escalation — T1068, T1112

1. Executive Summary

MiniPlasma is an unpatched Windows privilege escalation zero-day — publicly released on 13 May 2026 — that allows any standard user account to escalate to SYSTEM on fully patched Windows 11 and Windows Server 2022/2025 systems. The underlying vulnerability, CVE-2020-17103, was originally reported to Microsoft by Google Project Zero researcher James Forshaw in September 2020 and was supposedly patched in December 2020. However, security researcher Nightmare-Eclipse (also known as Chaotic Eclipse) discovered that either the patch was never applied correctly or was silently rolled back: the original proof-of-concept code continues to work without any modification against the latest May 2026 updates.

Once SYSTEM-level access is achieved through MiniPlasma, an attacker has unrestricted control over the compromised machine. From that foothold they can disable endpoint security tools, dump credentials from LSASS, install persistent backdoors, and pivot laterally to other systems on the network. The exploit is publicly available on GitHub, has accumulated over 390 stars within days of publication, and has been confirmed as functional by independent researchers at ThreatLocker and others. MiniPlasma is the sixth consecutive Windows zero-day released by the same researcher in six weeks; three earlier exploits in the same series — BlueHammer, RedSun, and UnDefend — were confirmed to have been weaponised in real-world attacks within days of public disclosure.

Microsoft has not issued an emergency patch and has not assigned a new CVE; their response was: 'Microsoft is investigating this report and will take appropriate action to protect customers as soon as possible.' The next scheduled Patch Tuesday is 10 June 2026. Until a fix is available, organisations must rely on compensating controls: default-deny application policies, registry-level monitoring, and stringent least-privilege enforcement. This report provides full technical analysis, MITRE ATT&CK mapping, detection rules (Sigma, KQL, YARA), threat hunt queries, and a prioritised remediation roadmap.

2. Vulnerability Details

2.1 Root Cause

The vulnerability resides in the HsmOsBlockPlaceholderAccess routine within the Windows Cloud Filter driver (cldflt.sys). This driver is the kernel-mode component responsible for cloud-backed file placeholder management in OneDrive and similar services, and is present by default on virtually all Windows 11 installations.

The root cause is a missing access-control flag: when the HsmOsBlockPlaceholderAccess function creates a registry key it fails to specify the OBJ_FORCE_ACCESS_CHECK flag in the OBJECT_ATTRIBUTES structure passed to ZwCreateKey. This flag is required to ensure that the operating system performs proper impersonation-aware access checks during kernel-initiated registry operations. Without it, the kernel opens registry paths using the machine context rather than the calling user's effective token, bypassing standard discretionary access control.

The exploit weaponises this omission via a race condition. The attack thread alternates the calling thread's token between a standard user token and the anonymous (null) token, creating a time-of-check/time-of-use window. When the race is won — reliably achievable on multi-core systems by running competing threads — the kernel's call to RtlOpenCurrentUser resolves to the .DEFAULT user

hive (HKEY_USERS\DEFAULT) while the thread's token has already been reverted to the unprivileged user context. The result is an unprivileged write to the .DEFAULT hive, which should be inaccessible to standard users. From this registry beachhead the exploit chains to SYSTEM-level code execution by placing a crafted key that causes a privileged service to load attacker-controlled code, ultimately spawning a SYSTEM shell.

The exploit abuses the undocumented CfAbortHydration API, part of the Cloud Filter framework, to trigger the vulnerable code path. The two registry paths that are manipulated are:

- \Registry\User\Software\Policies\Microsoft\CloudFiles\BlockedApps* — used during the trigger phase
- \Registry\User\DEFAULT\Volatile Environment* — the final unauthorised write target

2.2 Affected Products

Product	Status	Notes
Windows 11 (all editions)	VULNERABLE	Confirmed on fully patched May 2026 build
Windows Server 2022	VULNERABLE	Confirmed affected
Windows Server 2025	VULNERABLE	Confirmed affected
Windows 10	Not Affected	Cloud Filter driver behaviour differs
Windows 11 Canary (Insider)	Not Affected	Noted by Will Dormann (Tharros)
Windows Server 2019 / 2016	Unknown	Not independently tested

2.3 Attack Scenarios

Scenario A — Insider / Disgruntled Employee

An employee with a standard domain account on a Windows 11 workstation downloads or compiles the public MiniPlasma PoC from GitHub. Running the executable from their standard account, they win the race condition (typically within seconds on modern multi-core hardware) and obtain a SYSTEM-level command prompt. From this shell they access LSASS to dump credentials, read files outside their normal permission boundary, and install a persistent backdoor before their account is revoked during offboarding.

Scenario B — Post-Exploitation Privilege Escalation

A threat actor gains an initial foothold via a phishing email delivering a macro-enabled document. The initial implant runs as the user's standard account. To escalate beyond the user's privilege tier — required to disable AV, disable EDR, or move laterally using pass-the-hash — the actor deploys MiniPlasma. Within the same session the implant elevates to SYSTEM, disables Windows Defender, dumps credentials from LSASS, and establishes persistence via a SYSTEM-context scheduled task. This mirrors the post-exploitation pattern observed with three earlier exploits in the Chaotic Eclipse series.

Scenario C — Ransomware Pre-Staging

A ransomware affiliate uses a separate initial-access exploit (e.g., a VPN vulnerability) to land a commodity RAT on an endpoint as a standard user. MiniPlasma is used to escalate to SYSTEM, after which the actor deletes Volume Shadow Copies (`vssadmin delete shadows /all`), disables Windows backup services, and deploys the ransomware payload under a SYSTEM-context process to maximise file encryption coverage, including files owned by other local accounts.

2.4 CVSS v3.1 Breakdown

Metric	Value	Rationale
Attack Vector	Local (L)	Attacker must be logged in as a standard user on the target system
Attack Complexity	High (H)	Race condition requires winning a timing window; reliable but not instant
Privileges Required	Low (L)	Only a standard user account is required — no admin rights needed
User Interaction	None (N)	Victim interaction is not required; entirely attacker-driven
Scope	Changed (C)	Escalation crosses a security boundary from user to kernel/SYSTEM
Confidentiality	High (H)	SYSTEM access allows reading all data on the system
Integrity	High (H)	SYSTEM access allows modifying any file, registry key, or system component
Availability	High (H)	SYSTEM access allows crashing, disabling, or destroying the system

3. Threat Landscape & Context

3.1 The Chaotic Eclipse Zero-Day Series

MiniPlasma is not an isolated event. It is the sixth publicly released zero-day exploit from a researcher operating under the aliases Nightmare-Eclipse (GitHub) and Chaotic Eclipse (blog), released over six consecutive weeks in spring 2026. The series began after the researcher alleged a personal grievance: 'I never wanted to reopen a blog and a new GitHub account to drop code. But someone violated our agreement and left me homeless with nothing.' Three of the earlier exploits — BlueHammer, RedSun, and UnDefend — were confirmed to have been actively exploited in real attacks within days of public disclosure, demonstrating the extremely short window between PoC release and in-the-wild weaponisation.

Exploit	Description	Status	Wild Exploitation
BlueHammer	Privilege escalation / BitLocker bypass	Patched	YES — confirmed
RedSun	Turns Defender into an attack tool	Patched	YES — confirmed
UnDefend	Degrades Defender detection capability	Patched	YES — confirmed
YellowKey	Targets BitLocker recovery environment	Unpatched	Not confirmed
GreenPlasma	Windows privilege escalation	Unpatched	Not confirmed
MiniPlasma	LPE via cldflt.sys race condition (CVE-2020-17103)	Unpatched	Not yet confirmed

3.2 Related CVEs

- **CVE-2025-62221** — A separate privilege escalation vulnerability in the same cldflt.sys Cloud Filter driver component, patched by Microsoft in December 2025. Microsoft confirmed it was actively exploited in the wild at the time of patching. The same component being exploited twice within six months demonstrates a persistent security posture weakness in this subsystem.
- **CVE-2020-17103** — The original vulnerability reported by James Forshaw (Google Project Zero) in September 2020. Microsoft issued a patch in December 2020 Patch Tuesday, but the patch appears to have been either incomplete or silently regressed, as the original PoC continues to work without modification.

3.3 Threat Actor Interest

The public availability of a reliable, weaponised exploit significantly raises the likelihood of near-term in-the-wild exploitation by multiple threat actor categories. Based on the pattern established by the three earlier exploits in this series, blue teams should treat the window from PoC release to first in-the-wild use as days, not weeks.

- Ransomware affiliates — MiniPlasma provides exactly the SYSTEM-level access required to disable shadow copies and AV before encryption

- Nation-state APTs — reliable LPE against fully patched Windows 11 and Server 2022/2025 is high-value for espionage operations
- Initial access brokers — can add MiniPlasma to post-exploitation toolchains to increase value of sold accesses
- Commodity malware operators — low skill barrier (the PoC compiles and runs directly) means broad adoption is likely

4. MITRE ATT&CK Mapping

Tactic	Technique / Sub-Technique	ID	Relevance to MiniPlasma
Privilege Escalation	Exploitation for Privilege Escalation	T1068	Direct — exploit of cldflt.sys race condition to achieve SYSTEM
Defense Evasion	Modify Registry	T1112	Direct — exploit writes unauthorised keys to .DEFAULT hive and CloudFiles registry paths
Defense Evasion	Impair Defenses: Disable or Modify Tools	T1562.001	Post-exploitation — SYSTEM access used to disable AV/EDR before secondary payload
Credential Access	OS Credential Dumping: LSASS Memory	T1003.001	Post-exploitation — SYSTEM required to read LSASS process memory
Persistence	Scheduled Task/Job: Scheduled Task	T1053.005	Post-exploitation — SYSTEM-context scheduled task for persistent backdoor
Persistence	Create or Modify System Process: Windows Service	T1543.003	Post-exploitation — create malicious service under SYSTEM context
Impact	Inhibit System Recovery	T1490	Post-exploitation (ransomware scenario) — delete VSS copies as SYSTEM
Lateral Movement	Use Alternate Authentication Material: Pass the Hash	T1550.002	Post-exploitation — use dumped NTLM hashes to authenticate to adjacent systems
Collection	Data from Local System	T1005	Post-exploitation — SYSTEM access removes file permission barriers for data collection

5. Mitigation

IMPORTANT: There is no official patch as of 20 May 2026. The controls below are compensating measures. They reduce attack surface but do not eliminate the vulnerability. Apply the vendor patch immediately when it becomes available — treat it as Critical priority regardless of normal patch cadence.

5.1 Primary Mitigation — Default-Deny Application Policy

The most effective current control is a default-deny application allowlisting policy (e.g., ThreatLocker Application Allowlisting, Windows Defender Application Control (WDAC), AppLocker). Such a policy prevents the MiniPlasma payload executable from running before it can reach the vulnerable code path. ThreatLocker has confirmed that their Application Allowlisting control blocks the exploit at execution regardless of the underlying driver vulnerability. This control is also effective against all other Chaotic Eclipse exploits in the series.

- Deploy WDAC in audit mode first to establish baseline, then enforce mode
- Block execution of any unsigned or unrecognised executable by non-admin users
- Review and restrict PowerShell execution policy to prevent script-based variants

5.2 Registry Monitoring (Detect & Alert)

Configure your EDR or SIEM to alert on writes to the following registry paths, which are the two manipulation points the exploit uses:

```
\Registry\User\Software\Policies\Microsoft\CloudFiles\BlockedApps*  
\Registry\User\.\DEFAULT\Volatile Environment*
```

Writes to either path from non-SYSTEM, non-privileged processes should be treated as high-confidence indicators of MiniPlasma exploitation. ThreatLocker has published community policy TL.REG.1747 — Mini Plasma Reg Key Created (published 18 May 2026) for their platform.

5.3 Principle of Least Privilege

- Audit and remove unnecessary local administrator rights from all end-user accounts
- Enroll high-value accounts in the Protected Users security group to restrict credential caching
- Implement account tiering: separate admin, service, and user accounts — never use admin accounts for daily tasks
- Disable or restrict OneDrive / cloud sync on sensitive systems where the Cloud Filter driver presence is not required

5.4 Network Segmentation & Lateral Movement Barriers

- Enforce host-based firewalls to limit SMB, WMI, and RPC access between workstations
- Deploy Microsoft LAPS or a PAM solution to ensure unique local administrator passwords per host
- Enable Credential Guard on Windows 11 endpoints to protect LSASS from memory-reading attacks
- Monitor for anomalous authentication events (Event ID 4624/4648) from hosts where exploitation may have occurred

5.5 Patch Readiness

- Subscribe to Microsoft Security Update Guide (MSRC) notifications to receive immediate alert when a patch is issued
- Pre-stage patch deployment pipeline so the fix can be pushed within hours of release — do not wait for a standard monthly cycle
- Treat the June 10, 2026 Patch Tuesday as a hard deadline; consider emergency patching if exploitation is confirmed in the wild before then

6. Detection

Detection for MiniPlasma should be layered. No single signal is sufficient. The primary high-fidelity signal is registry write activity to the two specific paths the exploit manipulates. Secondary signals include process anomalies associated with privilege escalation chains and post-exploitation behaviours.

6.1 Windows Event Log Indicators

Event ID	Log / Source	MiniPlasma Relevance
4657	Security	Registry value modified — key path matches \Registry\User\DEFAULT\Volatile Environment or CloudFiles\BlockedApps
4663	Security (Object Audit)	Registry key access — specifically from non-SYSTEM processes writing to .DEFAULT hive
1	Sysmon	Process creation — MiniPlasma spawns cmd.exe or PowerShell with SYSTEM privileges from a non-SYSTEM parent
13	Sysmon	Registry value set — EventType SetValue, TargetObject containing .DEFAULT\Volatile Environment
14	Sysmon	Registry key renamed — associated with post-race-condition registry manipulation
4688	Security	Process creation — cmd.exe or conhost.exe spawned with elevated SID from standard-user parent process
4697	Security	New service installed — post-exploitation persistence via SYSTEM-context service creation
4698	Security	Scheduled task created — post-exploitation persistence
7045	System	New service installed — alternative to 4697 if Security audit not enabled

6.2 Sigma Rule — Registry Write to .DEFAULT Hive

```
title: MiniPlasma Registry Write to .DEFAULT Volatile Environment
id: a7f3b9d2-1e4c-4a8f-9b5e-2d3c4f5a6b7c
status: experimental
description: >
  Detects unauthorised writes to HKEY_USERS\DEFAULT\Volatile Environment, a
  key indicator of MiniPlasma (CVE-2020-17103) exploitation via the clflt.sys
  race condition.
references:
  - https://github.com/Nightmare-Eclipse/MiniPlasma
  - https://project-zero.issues.chromium.org/issues/42451192
author: Purple Team — RAIconoon
date: 2026-05-20
tags:
  - attack.privilege_escalation
  - attack.t1068
```

```

- attack.t1112
logsource:
  product: windows
  category: registry_set
detection:
  selection:
    EventType: SetValue
    TargetObject|contains:
      - '\Registry\User\DEFAULT\Volatile Environment'
      - 'SOFTWARE\Policies\Microsoft\CloudFiles\BlockedApps'
  filter_system:
    SubjectUserName|endswith: '$'
  filter_legit:
    Image|contains:
      - '\Windows\System32\svchost.exe'
      - '\Windows\System32\services.exe'
  condition: selection and not filter_system and not filter_legit
falsepositives:
  - Legitimate cloud sync service operations (validate Image path carefully)
  - Group Policy application by SYSTEM account
level: high

```

6.3 Sigma Rule — SYSTEM Shell from Standard User Parent

```

title: MiniPlasma Suspicious SYSTEM Shell Spawned
id: b8e2c1f4-2d5a-4b9e-8c6f-3e4d5f6a7b8c
status: experimental
description: >
  Detects cmd.exe or PowerShell spawned with SYSTEM-level token from a parent
  process running under a standard user account – consistent with MiniPlasma
  or similar LPE exploitation chain.
references:
  - https://github.com/Nightmare-Eclipse/MiniPlasma
author: Purple Team – RAICoon
date: 2026-05-20
tags:
  - attack.privilege_escalation
  - attack.t1068
logsource:
  product: windows
  category: process_creation
detection:
  selection_child:
    Image|endswith:
      - '\cmd.exe'
      - '\powershell.exe'
      - '\pwsh.exe'
    IntegrityLevel: System
  filter_expected_parents:
    ParentImage|contains:
      - '\services.exe'

```

```

- '\svchost.exe'
- '\lsass.exe'
- '\wininit.exe'
- '\csrss.exe'
- '\smss.exe'
- '\taskeng.exe'
- '\msiexec.exe'

condition: selection_child and not filter_expected_parents
falsepositives:
- Some legitimate administrative tooling spawning SYSTEM shells
- IT automation tools – validate against change management records
level: high

```

6.4 Microsoft Defender for Endpoint — KQL

```

// CVE-2020-17103 / MiniPlasma – Registry Write to .DEFAULT Volatile Environment
// Run in Microsoft Defender for Endpoint Advanced Hunting
DeviceRegistryEvents
| where Timestamp > ago(30d)
| where ActionType == "RegistryValueSet"
| where RegistryKey has_any (
    @"\Registry\User\.DEFAULT\Volatile Environment",
    @"SOFTWARE\Policies\Microsoft\CloudFiles\BlockedApps"
)
| where InitiatingProcessAccountName !endswith "$" // exclude machine accounts
| where InitiatingProcessFileName !in~ ("svchost.exe", "services.exe", "lsass.exe")
| project Timestamp, DeviceName, InitiatingProcessAccountName,
    InitiatingProcessFileName, InitiatingProcessCommandLine,
    RegistryKey, RegistryValueName, RegistryValueData
| order by Timestamp desc

```

```

// CVE-2020-17103 / MiniPlasma – SYSTEM Shell from Unexpected Parent
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe")
| where ProcessTokenElevationType == "System"
| where InitiatingProcessFileName !in~ (
    "services.exe", "svchost.exe", "lsass.exe",
    "wininit.exe", "csrss.exe", "smss.exe",
    "taskeng.exe", "msiexec.exe", "WmiPrvSE.exe"
)
| project Timestamp, DeviceName, AccountName,
    InitiatingProcessFileName, FileName, ProcessCommandLine
| order by Timestamp desc

```

6.5 YARA Rule — MiniPlasma Exploit Binary

```

rule MiniPlasma_CVE_2020_17103 {
    meta:

```

```
description = "Detects the MiniPlasma PoC exploit binary targeting CVE-2020-17103"
author      = "Purple Team - RAiccoon"
date        = "2026-05-20"
reference    = "https://github.com/Nightmare-Eclipse/MiniPlasma"
severity     = "high"
hash_note   = "Update with confirmed SHA256 of compiled binary"
strings:
  $str1 = "MiniPlasma" ascii wide
  $str2 = "CVE-2020-17103" ascii wide
  $str3 = "CfAbortHydration" ascii wide
  $str4 = "HsmOsBlockPlaceholderAccess" ascii wide
  $str5 = "\.DEFAULT\\Volatile Environment" ascii wide nocase
  $str6 = "Nightmare-Eclipse" ascii wide
  $api1 = "RtlOpenCurrentUser" ascii
  $api2 = "NtSetInformationThread" ascii
condition:
  uint16(0) == 0x5A4D and // PE header
  filesize < 5MB and
  (
    2 of ($str*) or
    ($api1 and $api2 and 1 of ($str*))
  )
}
```

7. Threat Hunting

The following hunts use the TaHiTI (Targeted Hunting integrating Threat Intelligence) framework. Run across at least 30 days of historical telemetry in a breach-assumed posture. Confirm required data sources are ingested before executing. Document findings using the hypothesis-based format below.

7.1 Hunt — Unauthorised .DEFAULT Hive Registry Writes

Hypothesis: If an attacker has exploited MiniPlasma (CVE-2020-17103) on a host, we will see registry write events to \Registry\User\DEFAULT\Volatile Environment or CloudFiles\BlockedApps paths from non-SYSTEM, non-privileged processes in the Windows Event or Sysmon registry event log.

Data sources required: Sysmon (Event ID 13/14) or Windows Security Audit (Event ID 4657/4663). Confirm registry audit is enabled: HKLM\SYSTEM\CurrentControlSet\Control\Lsa\AuditRegistryGranularity must be enabled, or Sysmon rule must target the relevant hive.

```
// Sysmon-based hunt (Event ID 13 – RegistryValueSet)
// Splunk SPL:
index=sysmon EventCode=13
  TargetObject IN (
    "*\\.\DEFAULT\\Volatile Environment*",
    "*\\.\CloudFiles\\BlockedApps*"
  )
  NOT User IN ("NT AUTHORITY\\SYSTEM", "NT AUTHORITY\\LOCAL SERVICE")
| stats count by _time, ComputerName, User, TargetObject, Image
| sort - _time
```

Triage: Any hit that is not from a SYSTEM account and not from svchost.exe / services.exe should be treated as a high-confidence indicator. Capture the full process tree, running processes on that host, and all subsequent authentication events from the affected account.

7.2 Hunt — Unexpected SYSTEM-Context Process Creation

Hypothesis: If MiniPlasma was successfully exploited, the attacker will have a shell or process running as SYSTEM (IntegrityLevel=System or SubjectUserSid=S-1-5-18) spawned from a parent process associated with a standard user session.

```
// KQL – MDE Advanced Hunting – Unexpected SYSTEM processes (30 days)
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessTokenElevationType == "System"
| where InitiatingProcessAccountSid != "S-1-5-18" // parent not already SYSTEM
| where FileName in~
("cmd.exe", "powershell.exe", "pwsh.exe", "whoami.exe", "net.exe", "wmic.exe")
| summarize count() by DeviceName, InitiatingProcessFileName, FileName,
InitiatingProcessAccountName
| order by count_ desc
```

7.3 Hunt — Post-Exploitation Persistence

Hypothesis: Following successful MiniPlasma exploitation, the attacker will install persistence. We expect to see new scheduled tasks, services, or registry Run keys created by a SYSTEM process within a short time window after an LPE event.

```
// KQL – New scheduled tasks created by SYSTEM (potential post-exploitation)
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName =~ "schtasks.exe"
| where ProcessCommandLine has "/create"
| where AccountName =~ "SYSTEM" or InitiatingProcessAccountName =~ "SYSTEM"
| where InitiatingProcessFileName !in~ ("services.exe", "svchost.exe", "msiexec.exe")
| project Timestamp, DeviceName, AccountName,
    InitiatingProcessFileName, ProcessCommandLine
| order by Timestamp desc
```

7.4 Hunt — Credential Dumping Following LPE

Hypothesis: After escalating to SYSTEM, the attacker will attempt to dump credentials from LSASS. We expect to see LSASS memory access events (OpenProcess with PROCESS_VM_READ on lsass.exe) from non-SYSTEM processes that recently executed a privilege escalation.

```
// KQL – LSASS memory access from non-native processes
DeviceEvents
| where Timestamp > ago(30d)
| where ActionType == "OpenProcessApiCall"
| where FileName =~ "lsass.exe"
| where InitiatingProcessFileName !in~ (
    "MsMpEng.exe", "csrss.exe", "werfault.exe",
    "taskmgr.exe", "svchost.exe", "perfmon.exe"
)
| project Timestamp, DeviceName, InitiatingProcessAccountName,
    InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc
```

8. Purple Team Exercise Plan

The following exercise plan is designed to validate detection coverage for MiniPlasma and related post-exploitation behaviours. Run as a Technique-Specific purple team exercise (assumed breach model — start from a standard user session on an isolated/test Windows 11 host).

SCOPE: Execute only in an isolated lab environment. Do NOT run against production systems. Obtain written authorisation before executing any test case. Ensure blue team is monitoring in real time.

8.1 Test Cases

#	Test Case	Red Team Action	Expected Blue Signal	ATT&CK
1	MiniPlasma LPE execution	Run MiniPlasma PoC as standard user on test host	Sysmon 13: .DEFAULT reg write; Sysmon 1: SYSTEM cmd.exe	T1068
2	LSASS credential dump post-LPE	Use ProcDump or Task Manager as SYSTEM to dump lsass.dmp	DeviceEvents: OpenProcessApiCall on lsass.exe	T1003.001
3	Scheduled task persistence	schtasks /create as SYSTEM with malicious command	Event 4698 + DeviceProcessEvents schtasks /create from SYSTEM	T1053.005
4	Service creation persistence	sc create malicious service as SYSTEM	Event 7045 / 4697: new service from non-standard image path	T1543.003
5	Defender disable post-LPE	Set-MpPreference -DisableRealtimeMonitoring \$true as SYSTEM	DeviceEvents: Tamper protection alert; AV state change event	T1562.001
6	VSS deletion (ransomware sim)	vssadmin delete shadows /all as SYSTEM (test VM only)	DeviceProcessEvents : vssadmin with delete shadows args	T1490

9. Recommended Actions Summary

Priority	Action	Timeline
P1 — CRITICAL	Monitor and alert on registry writes to \Registry\User\DEFAULT\Volatile Environment and CloudFiles\BlockedApps	NOW
P1 — CRITICAL	Deploy or verify default-deny application allowlisting policy (WDAC / ThreatLocker / AppLocker)	Within 24h
P1 — CRITICAL	Subscribe to MSRC alerts — apply vendor patch immediately on release (estimated June 10, 2026)	Ongoing
P2 — HIGH	Deploy Sigma rules 6.2 and 6.3 in SIEM in alert mode	Within 48h
P2 — HIGH	Deploy KQL queries 6.4 to MDE Advanced Hunting as continuous detection rules	Within 48h
P2 — HIGH	Run 30-day historical threat hunt using queries in Section 7	Within 72h
P2 — HIGH	Enable Credential Guard on all Windows 11 endpoints	Within 1 week
P3 — MEDIUM	Conduct purple team exercise per Section 8 to validate detection coverage	Within 2 weeks
P3 — MEDIUM	Audit and remove unnecessary local admin rights from all end-user accounts	Within 1 week
P3 — MEDIUM	Update YARA rule 6.5 with confirmed SHA256 hash of compiled MiniPlasma binary	As samples are identified
P3 — MEDIUM	Evaluate disabling OneDrive / cldft.sys on systems where cloud sync is not operationally required	Within 2 weeks
P4 — LOW	Update incident response playbook to include MiniPlasma LPE scenario	Within 1 month
P4 — LOW	Produce patch deployment compliance report post-June 10 Patch Tuesday	Post-June 10

10. References

- [1] Nightmare-Eclipse, "MiniPlasma — CVE-2020-17103 PoC", GitHub, May 13 2026. <https://github.com/Nightmare-Eclipse/MiniPlasma>
- [2] Abinaya, "New Windows MiniPlasma Zero-Day Let Attackers Gain SYSTEM Access — PoC Released", Cyber Security News, May 18 2026. <https://cybersecuritynews.com/windows-mini-plasma-zero-day/>
- [3] Pomaranski, A., "MiniPlasma: Windows privilege escalation zero-day affects fully patched systems", ThreatLocker Blog, May 19 2026. <https://www.threatlocker.com/blog/mini-plasma-windows-privilege-escalation-zero-day-affects-fully-patched-systems>
- [4] Naraine, R., "Researcher Drops MiniPlasma Windows Exploit for Unpatched 2020 CVE", SecurityWeek, May 2026. <https://www.securityweek.com/researcher-drops-mini-plasma-windows-exploit-for-unpatched-2020-cve/>
- [5] Kovacs, E., "New Windows MiniPlasma Zero-Day Let Attackers Gain SYSTEM Access", The Hacker News, May 2026. <https://thehackernews.com/2026/05/mini-plasma-windows-0-day-enables-system.html>
- [6] Goodin, D., "'Patched' Windows bug resurfaces 6 years later as working SYSTEM-level exploit", CSO Online. <https://www.csoonline.com/article/4172320/patched-windows-bug-resurfaces-6-years-later-as-working-system-level-exploit.html>
- [7] James Forshaw, Google Project Zero Issue #42451192 — original vulnerability report (September 2020). <https://project-zero.issues.chromium.org/issues/42451192>
- [8] Barracuda Networks Blog, "Nightmare-Eclipse: six zero-days, six weeks and one big grudge", May 19 2026. <https://blog.barracuda.com/2026/05/19/nightmare-eclipse-zero-days-grudge>
- [9] Security Affairs, "Chaotic Eclipse discloses MiniPlasma zero-day, suggesting a missing or undone 2020 Windows security fix". <https://securityaffairs.com/192325/hacking/chaotic-eclipse-discloses-mini-plasma-zero-day-suggesting-a-missing-or-undone-2020-windows-security-fix.html>
- [10] CIRT Jamaica, "MiniPlasma Windows Zero-Day Vulnerability Enables SYSTEM-Level Privilege Escalation". <https://cirt.gov.jm/advisory/mini-plasma-windows-zero-day-vulnerability-enables-system-level-privilege-escalation>
- [11] MITRE ATT&CK — T1068: Exploitation for Privilege Escalation. <https://attack.mitre.org/techniques/T1068/>
- [12] MITRE ATT&CK — T1112: Modify Registry. <https://attack.mitre.org/techniques/T1112/>
- [13] Microsoft MSRC — CVE-2020-17103 Advisory. <https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2020-17103>
- [14] ThreatLocker Community Policy TL.REG.1747 — Mini Plasma Reg Key Created, published May 18 2026. <https://www.threatlocker.com/platform-archive/community>

END OF REPORT — TLP: AMBER — Handle in accordance with your organisation's information handling policy